

## OVERVIEW OF THE PROCESSING

*Controller(s)*

| Field                   | Value                                                                              |
|-------------------------|------------------------------------------------------------------------------------|
| Controller              | Operator of revenue financing, contract, remittance, or commercial funding product |
| DPO or similar function | Controller DPO or privacy contact                                                  |
| Repository evidence     | Consumers/VAU_MONEY; contractsClient.js; financingClient.js; shycontracts          |

*Name of the Processing*

**Internal name:** Shyware Revenue Financing / Contracts DPIA

---

## SYSTEMATIC DESCRIPTION OF THE PROCESSING

*High-level Description of the Processing*

### Processed Personal Data

| # | Personal Data Item                 | Data Type / Data Subject Category                        | Sensitivity |
|---|------------------------------------|----------------------------------------------------------|-------------|
| 1 | Business/customer account data     | Founder, business owner, payer, customer, admin          | Medium      |
| 2 | Revenue/remittance record          | Contract id, matched amount, payment/remittance metadata | Financial   |
| 3 | KYB/KYC status                     | Entity and beneficial owner verification                 | High        |
| 4 | Contract eligibility/decision data | Funding status, adverse action, risk score or gate       | High        |

**Purposes of the Processing** Support contract registration, activation, revenue remittance, audit, anti-fraud, KYB/KYC, and compliance workflows.

## ANALYSIS OF THE PROCESSING

*Lawfulness and Minimisation*

Customer controllers must assess lending, financing, adverse-action, credit, KYB/KYC, and consumer/business finance rules. If automated eligibility or adverse-action logic is used, additional transparency and contestability controls are required.

## Mainhub Patent Alignment

The Mainhub patent architecture can reduce canonical-state linkage between account identity and financing/remittance records. It does not make eligibility scoring, adverse-action logic, revenue data, KYB/KYC, repayment behavior, or contract enforcement anonymous. Financing deployments must separately assess profiling, explainability, human review, and financial-record retention.

**Authority Partition** This is a count-match embodiment. Four structurally separated parties are required:

| Authority                                                       | Role                                               |
|-----------------------------------------------------------------|----------------------------------------------------|
| Auth (Cognito)                                                  | Account layer; always required; gates access to II |
| IDV/KYC (Dedit)                                                 | Verifies lender and borrower identity on authenti  |
| Eligibility authority (financing platform, lender, or investor) | Determines financing eligibility and contract acti |
| Reconciling authority                                           | Off-chain linkage store + sealer keys              |

**Dual co-authorization enforcement (Claim 2):** The validation layer must reject single-signature rescission transactions. **VERIFIED (run 26369476939):** *DUAL\_COSIG section passes 379/379 — unauthenticated + valid token → 401; authenticated + no token → 400; both co-signatures → 200, countMatch preserved.*

## CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The financing/contracts pattern may be proportionate only where revenue data, eligibility assessment, remittance tracking, and enforcement workflows are necessary for the financing product. Canonical unlinkability does not justify opaque scoring, unexplained adverse action, or excessive financial-record retention. Production should wait until profiling, explainability, human review, dispute, retention, and contract-enforcement controls are fixed.

## RISK ASSESSMENT AND MANAGEMENT

| # | Risk                                  | Required Follow-up                                     |
|---|---------------------------------------|--------------------------------------------------------|
| 1 | Financial profiling                   | See <code>patent/mainhub/dpia/evidence_index.md</code> |
| 2 | Unfair or opaque eligibility decision | See <code>patent/mainhub/dpia/evidence_index.md</code> |
| 3 | KYB/KYC transfer risk                 | See <code>patent/mainhub/dpia/evidence_index.md</code> |
| 4 | Contract/remittance linkage           | See <code>patent/mainhub/dpia/evidence_index.md</code> |

## DPIA Audit Findings

This DPIA is the audit record for revenue financing and contract deployments. Before production, the DPIA must identify the provider partition across KYB/KYC or account provider, financing

operator, payment/remittance provider, protected linkage store, reconciling authority, canonical commit authority, and telemetry/support providers. Canonical-state unlinkability does not reduce risks from eligibility scoring, revenue data, repayment behavior, adverse action, explainability, dispute handling, or contract enforcement. The software evidence may be complete while the domain deployment still requires profiling, human review, retention, appeal, and lawful-access controls.

**Operator Compliance Instructions** For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** (`patent/mainhub/dpia/source/COM` published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production. Template in Compliance Guide §Operator Obligations.
- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that `eligibility_authority_key`  $\neq$  `reconciling_authority_key`  $\neq$  `auth_key`.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

### *Residual Risk Assessment*

The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. See `patent/mainhub/dpia/evidence_index.md` and `patent/mainhub/composition.tex` for the linked reduction-to-practice and consumer test artifacts. These scores describe residual domain risk after the software path is validated; they do not say the kernel tests were missing. Scores above the acceptable threshold reflect financing, eligibility scoring, adverse action, revenue-data, enforcement, KYB/KYC, or payment choices that still require deployment-level controls.

| Risk                                            | Additional Measures Applied                                                    |
|-------------------------------------------------|--------------------------------------------------------------------------------|
| Eligibility scoring or adverse-action profiling | Human review, explainability, appeal process, and feature minimization         |
| Revenue or repayment data exposure              | Retention limits, access controls, payment minimization, and proof of payment  |
| Contract enforcement overreach                  | Typed actions, audit logs, notice, and dispute workflow                        |
| KYB/KYC provider breach                         | Subprocessor review, transfer controls, retention limits, and proof of payment |

| Risk                   | Additional Measures Applied                                   |
|------------------------|---------------------------------------------------------------|
| Provider consolidation | Provider matrix for KYB/KYC, financing, payment, linkage, rec |

## INVOLVEMENT OF INTERESTED PARTIES

Privacy counsel, financial-regulatory counsel, credit/underwriting or financing stakeholders, payment teams, security, and customer DPO teams should review this DPIA before production. Data subject or customer representative consultation may be appropriate where adverse action, small-business financing, or materially consequential eligibility decisions may occur.

## CONCLUSION AND DECISION

**Draft decision:** Separate DPIA and finance-law review required before production launch.

## Regulatory and Deployment Context Annexes

### Annex A — Deployment Context Variants

| Deployment context                                               | Elevated risk                                                       | Regulatory trigger                                                               | Additional requirement                                                                                                                      |
|------------------------------------------------------------------|---------------------------------------------------------------------|----------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Consumer revenue-based financing</b>                          | Adverse action; credit reporting; UDAAP                             | US Equal Credit Opportunity Act (ECOA); CFPB UDAAP; EU Consumer Credit Directive | Adverse action notice with specific reasons; ECOA-prohibited factor exclusion; right to explanation                                         |
| <b>SME / B2B revenue financing</b>                               | KYB requirements; beneficial ownership; commercial credit reporting | FinCEN CDD Rule; EU AMLD5; commercial credit bureau reporting                    | UBO verification; entity sanctions screening; reporting to commercial credit bureaus if applicable                                          |
| <b>Secondary-market stake transfers</b> (shywire transfer layer) | Securities law if stake is a security; transfer restrictions        | US SEC Reg D/CF/A+; EU Prospectus Regulation                                     | Legal opinion on security classification before enabling secondary market; transfer restriction logic in smart contract or governance layer |
| <b>EU consumer micro-lending</b>                                 | GDPR Art. 22 automated decisions; explainability                    | EU Consumer Credit Directive 2023; GDPR Art. 22                                  | Human review override for rejections; meaningful explanation of automated eligibility decision                                              |

## Annex B — Adverse Action and Explainability

Automated eligibility scoring that results in a rejection or adverse terms is regulated independently of privacy law:

- **GDPR Art. 22:** Automated individual decision-making with legal or similarly significant effects requires either explicit consent, contractual necessity, or EU/member-state law authorisation. The data subject has the right to obtain human intervention, express their point of view, and contest the decision. shycontracts-v1’s structural anonymity of the canonical financing record does not exempt the operator from this obligation: the eligibility scoring is upstream of the canonical write and produces the adverse action before anonymisation occurs.
- **ECOA / Reg B (US):** Creditors must provide a written adverse action notice within 30 days stating the specific reasons for denial. Algorithmic or model-based reasons must be translatable into specific, principal reasons that a human can understand and contest.
- **EU AI Act (2024):** AI systems used for creditworthiness assessment of natural persons are classified as high-risk under Annex III. Operators must register, conduct conformity assessment, maintain technical documentation, and implement human oversight.

## Annex C — Financial Record Retention

- **US (SEC Rule 17a-4):** Broker-dealer records must be retained for 6 years; first 2 years in accessible format. If the financing platform intermediates securities, this retention obligation applies to the canonical financing records and off-chain linkage.
- **EU (MiFID II / EMIR):** Transaction records for regulated instruments must be retained for 5–7 years depending on instrument type.
- **General tax records:** Most jurisdictions require 5–7 year retention of financial transaction records for tax purposes. The `retention.canonical_records_days` and `retention.off_chain_linkage_cron` shyconfig fields must be configured to satisfy the applicable retention period before deletion cron executes.